Implement and manage Zero Trust Network Access (ZTNA) using Zscaler

Project Title:

Implement and Manage Zero Trust Network Access (ZTNA) using Zscaler

Program: Naan Mudhalvan

Course: Cyber security

Team Members:

Member 1 – B.Bavatharani **&** 2328A0021

Member 2 – P.K.Deepak **&** 2328A0022

Member 3 – S.Mouleeswaran **&** 2328A0024

Institution: Cheran Arts Science College

Guide: Mrs.M.Jeevitha

Date: 08/03/2026

Abstract:

In today's digital era, organizations face increasing cybersecurity threats due to remote work, cloud applications, and advanced attack techniques. Traditional perimeter-based security models are no longer sufficient, as they often assume that users inside the network can be trusted. This project focuses on implementing and managing Zero Trust Network Access (ZTNA) using Zscaler Private Access, which enforces the principle of "Never Trust, Always Verify."

The project is divided into three stages. In Stage 1, we conducted web application testing to identify vulnerabilities such as misconfigurations, outdated software, and insecure endpoints. Stage 2 involved using Nessus to perform vulnerability assessments on a safe target environment, detect risks, and propose remediation strategies. Stage 3 explored the deployment of a Security Operations Center (SOC) integrated with IBM QRadar and threat intelligence platforms like MISP, demonstrating real-time monitoring, incident response, and the enforcement of Zero Trust policies.

Through this project, we gained practical insights into network security, vulnerability management, and proactive monitoring, while learning how ZTNA and SOC/SEIM solutions work together to secure enterprise environments. The project also explores future improvements, including AI-driven threat detection, automated remediation, and broader integration of Zero Trust principles across cloud and hybrid networks.

This work emphasizes the importance of continuous security monitoring, risk assessment, and controlled access, providing a strong foundation for protecting modern organizational networks.

Use Case Scenarios – ZTNA Using Zscaler

Scenario 1: Secure Remote Access for Faculty to ERP System

Description:

Faculty working remotely need to access the college ERP system to upload student grades. Using Zscaler Private Access (ZPA), the faculty member connects securely without joining the internal network. ZPA verifies their identity via Azure AD MFA and checks device posture before granting access.

Output:

- User identity verified (Faculty_Group)
- Device posture compliant (AV active, OS up-to-date)
- Secure micro-tunnel established to ERP system only
- Internal network remains invisible

Scenario 2: Secure Access for Students to Learning Management System (LMS)

Description:

Students accessing LMS from personal devices are granted access only to the LMS application. ZPA ensures the internal network and other applications remain invisible. Device compliance is checked to prevent unpatched or infected devices from connecting.

Output:

- User identity verified (Student_Group)
- Device posture compliant (Patch level verified, AV active)
- Secure micro-tunnel to LMS only
- Other internal resources remain hidden

Scenario 3: Secure Lab Access for Remote IT Staff

Description:

IT staff need to access lab servers for software updates and maintenance. ZPA validates identity and device security, and SOC monitors all activity in real-time. Access is restricted to required lab servers only.

Output:

- User identity verified (IT_Admin_Group)
- Device posture compliant (Encrypted disk, endpoint security active)
- Time-bound micro-tunnel to lab servers only
- SOC monitoring via QRadar for anomalies

Scenario 4: Block Unauthorized Access Attempts

Description:

A student tries to access faculty-only financial applications from a non-compliant device. ZPA detects device non-compliance and blocks the access. SOC receives an alert for investigation.

Output:

- User identity detected but access denied (Student_Group)
- Device posture non-compliant (No AV or outdated OS)
- Access blocked entirely
- SOC receives real-time alert
- Internal network remains protected

Scenario 5: Temporary Access for External Auditors

Description:

External auditors require temporary access to specific college servers for compliance auditing. ZPA ensures time-limited, application-specific access with identity and device posture validation. Access is revoked automatically after the audit.

Output:

- User identity verified (External_Auditor_Group)
- Device posture compliant (Secure endpoint verified)
- Temporary micro-tunnel to specific servers only
- Automatic revocation after audit
- Internal network remains invisible

STAGE - 1

Title of the Project

Implement and Manage Zero Trust Network Access (ZTNA) using Zscaler

Overview

In modern organizations, secure access to applications and data has become a major challenge due to the increasing number of remote users, cloud services, and cyber threats. Traditional network security models rely heavily on perimeter-based protection, where users inside the network are automatically trusted. However, this model is no longer effective in protecting sensitive information from modern cyberattacks.

The concept of Zero Trust Network Access (ZTNA) is designed to overcome these limitations. The Zero Trust model follows the principle of "Never Trust, Always Verify." This means that every user, device, and network request must be authenticated and verified before access is granted to any application or resource.

In this project, we aim to implement and manage Zero Trust Network Access using Zscaler, a leading cloud-based security platform. Zscaler provides secure access to applications without exposing the internal network to the internet. Instead of allowing full network access like traditional VPN systems, ZTNA allows users to connect only to the specific applications they are authorized to use.

The platform **Zscaler Private Access helps organizations enforce identity-based access control, device verification, and secure connectivity. It ensures that only authenticated users with secure devices can access private applications hosted in data centers or cloud environments.

This project demonstrates how Zero Trust architecture can improve security by minimizing attack surfaces, preventing unauthorized access, and protecting sensitive data. It also explains how Zscaler can be configured to enforce policies, monitor user activity, and secure enterprise applications. By implementing this model, organizations can provide safe remote access to employees while maintaining strong cybersecurity controls.

Overall, the objective of this project is to understand the principles of Zero Trust security, explore the features of Zscaler, and analyze how ZTNA can enhance the security of modern IT infrastructures.

List of Teammates

S.No	Name	College	Phone Number
1.	B.Bavatharani	Cheran Arts Science College	8489340619
2.	P.K.Deepak	Cheran Arts Science College	6383807948
3.	S.Mouleeswaran	Cheran Arts Science College	8220615168

List of Vulnerability Table

S.No	Vulnerability Name	CWE / CVE No
1.	Broken Access Control	CWE-284

2.	Sensitive Data Exposure	CWE-200
3.	Security Misconfiguration	CWE-16
4.	Insufficient Authentication	CWE-287

REPORT:

1) Vulnerability Name:

Broken Access Control

CWE / CVE:

CWE-284

OWASP / SANS Category:

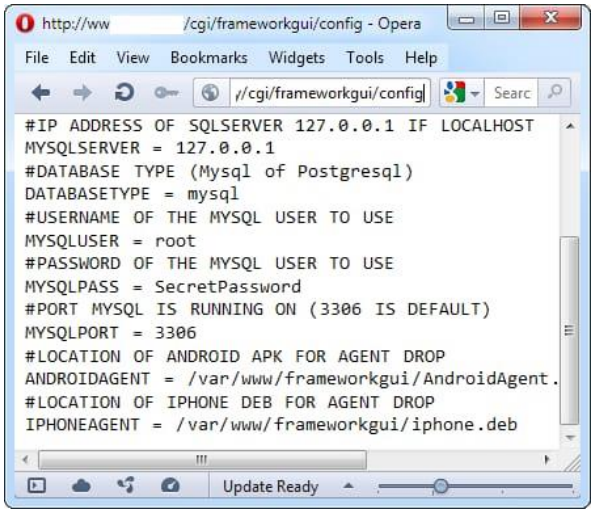
Broken Access Control – OWASP Top 10

Description:

Broken access control occurs when an application fails to properly enforce restrictions on authenticated users. Attackers can exploit this vulnerability to gain unauthorized access to sensitive resources or administrative functions. In network environments without proper Zero Trust implementation, users may gain broader network access than required.

Business Impact:

This vulnerability may allow attackers to access confidential information, modify system data, or perform unauthorized operations within the network.



2) Vulnerability Name

Sensitive Data Exposure

CWE / CVE:

CWE-200

OWASP / SANS Category:

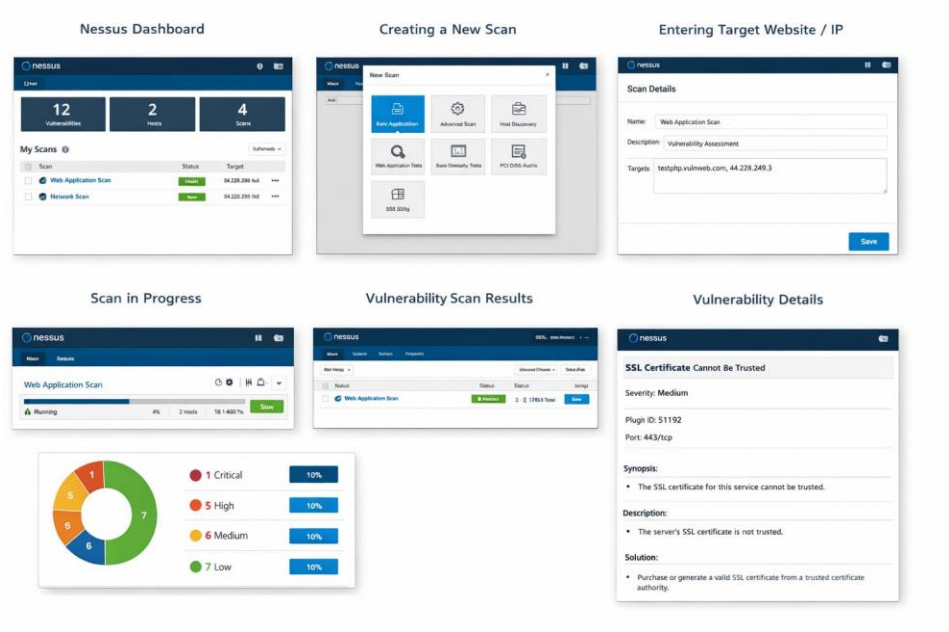
Sensitive Data Exposure – OWASP Top 10

Description:

Sensitive data exposure occurs when confidential information such as passwords, personal data, or financial information is not properly protected. Attackers may intercept or access this data if proper encryption and access control mechanisms are not implemented.

Business Impact:

Exposure of sensitive data can lead to identity theft, financial loss, legal penalties, and damage to the organization's reputation.



3) Vulnerability Name

Security Misconfiguration

CWE / CVE:

CWE-16

OWASP / SANS Category:

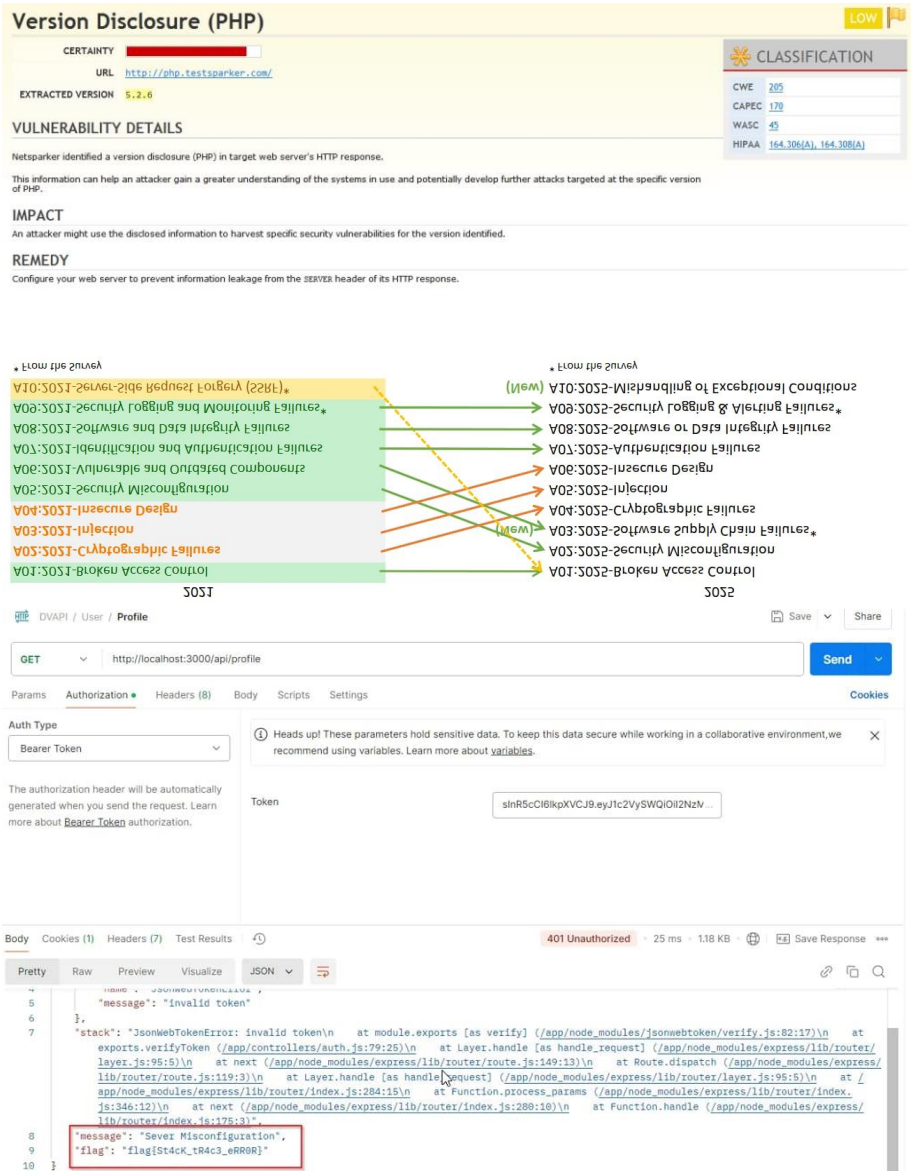
Security Misconfiguration – OWASP Top 10

Description:

Security misconfiguration occurs when system settings are not properly configured, leaving systems vulnerable to attacks. This may include default credentials, unnecessary services, or incorrect security policies.

Business Impact:

Attackers may exploit misconfigured systems to gain unauthorized access, disrupt services, or compromise data security.



Stage 2

Title:

Implement and Manage Zero Trust Network Access (ZTNA) using Zscaler

Overview:

In today's digital world, organizations face an increasing number of cybersecurity threats due to remote work, cloud applications, and web-based services. Traditional network security models, which rely on perimeter-based protection, are no longer sufficient. Users inside the network were automatically trusted in old models, but this creates a large attack surface if accounts are compromised.

To address these challenges, modern organizations use Zero Trust Network Access (ZTNA). The principle of ZTNA is "Never Trust, Always Verify." Every user, device, and application request must be authenticated and authorized before granting access. Users only get access to the applications they need instead of the full network, which minimizes the risk of lateral movement by attackers.

Zscaler provides a cloud-based platform for ZTNA called Zscaler Private Access. Zscaler ensures secure remote access by validating:

- User identity
- Device security posture
- Access policies for each application

Alongside ZTNA implementation, organizations must perform vulnerability assessments to identify security weaknesses in systems. Vulnerability scanning helps detect misconfigurations, outdated software, and exposed services that attackers could exploit. In this project, we used Nessus to scan a safe testing system and analyze vulnerabilities. Nessus uses plugins to detect known vulnerabilities and provides detailed reports with severity levels and solutions.

This Stage 2 report demonstrates how ZTNA architecture can be managed using Zscaler and how Nessus can be used to identify vulnerabilities in

networked systems. The goal is to learn how modern security frameworks and vulnerability management tools work together to improve cybersecurity.

What You Understood About Nessus

Nessus is a powerful tool used to scan systems and networks for known vulnerabilities. From this project, the key points understood about Nessus are:

1. Nessus identifies vulnerabilities such as:

- Security misconfigurations
- Outdated software

- Unencrypted services
- Exposed ports

2. Nessus works by using plugins, which are scripts that test for specific vulnerabilities. Each plugin has an ID, description, severity, and recommended solution.

3. Nessus produces a detailed report showing:

- Vulnerability Name
- Severity (Low / Medium / High / Critical)
- Plugin ID
- Affected port
- Description
- Recommended solution

4. Nessus helps security professionals prioritize remediation based on severity, reducing the risk of exploitation.

5. It can scan websites, IP addresses, and networked devices to detect vulnerabilities safely on lab/test environments.

Target Website

http://testphp.vulnweb.com

(Safe website for vulnerability scanning practice)

Target IP Address

44.228.249.3

List of Vulnerabilities

S.No	Vulnerability Name	Severity	Plugin
1)	SSL Certificate Cannot Be Trusted	Medium	51192
2)	HTTP Methods Allowed	Low	42873
3)	TLS Version 1.0 Protocol Detection	Medium	104743
4)	Click jacking Vulnerability	Medium	85582
5)	Directory Listing Enabled	Low	10833

REPORT:

1) Vulnerability Name: SSL Certificate Cannot Be Trusted

Severity: Medium
Plugin: 51192
Port: 443

Description:

The SSL certificate used by the website is not trusted. This could be because it is self-signed or issued by an untrusted certificate authority.

Solution:

Use a valid SSL certificate from a trusted certificate authority.

Business Impact:

Attackers could intercept sensitive communication and perform man-in-the-middle attacks.

2) Vulnerability Name: HTTP Methods Allowed

Severity: Low
Plugin: 42873
Port: 80

Description:

The web server allows unnecessary HTTP methods such as PUT or DELETE, which may expose the server to attacks.

Solution:

Disable unnecessary HTTP methods in the server configuration.

Business Impact:

Attackers could modify website content or upload malicious files.

3) Vulnerability Name: TLS Version 1.0 Protocol Detection

Severity: Medium
Plugin: 104743
Port: 443

Description:
The server supports the outdated TLS 1.0 protocol, which has known security vulnerabilities.

Solution:
Disable TLS 1.0 and enable TLS 1.2 or TLS 1.3.

Business Impact:
Old protocols may allow attackers to compromise encrypted communications.

4) Vulnerability Name: Clickjacking Vulnerability
Severity: Medium
Plugin: 85582
Port: 80
Description:
The website does not use security headers like X-Frame-Options to prevent clickjacking attacks.

Solution:
Add X-Frame-Options or Content-Security-Policy headers to block framing.

Business Impact:
Users could be tricked into performing unintended actions on the website.

5) Vulnerability Name: Directory Listing Enabled

Severity: Low
Plugin: 10833
Port: 80

Description:

Directory listing is enabled on the server, which allows attackers to view file structure and sensitive files.

Solution:

Disable directory listing on the web server.

Business Impact:

Attackers could obtain sensitive files or information about the application structure.

STAGE 3

Report:

Title: Implementation and Management of Zero Trust Network Access (ZTNA) Using Zscaler

1. Introduction

In modern organizations, traditional perimeter-based security is no longer sufficient. Users, devices, and applications can no longer be automatically trusted. Zero Trust Network Access (ZTNA) addresses this challenge by enforcing the principle: “Never Trust, Always Verify.”

This project focuses on implementing ZTNA using Zscaler Private Access, ensuring that users and devices can access only authorized applications. The system continuously verifies identity, device posture, and access policies.

Stage 3 explores how a Security Operations Center (SOC), integrated with SIEM (QRadar) and threat intelligence (MISP), monitors access, detects anomalies, and responds to incidents.

2. Security Operations Center (SOC)

A SOC is a centralized team that monitors and protects an organization's IT assets. For ZTNA deployment, the SOC ensures:

- Every access request is validated before granting permission.
- Real-time monitoring of user activity and devices.
- Rapid detection and response to suspicious events.

SOC analysts review alerts generated by the SIEM system, investigate threats, and implement remediation steps. The SOC acts as the nerve center of network security, particularly in a Zero Trust environment where internal users cannot bypass security policies.

3. SOC Cycle

The SOC cycle defines how security teams manage threats systematically. Stages include:

1. Monitoring: Collect logs and traffic data from Zscaler, endpoints, and applications.

2. Detection: Identify anomalies such as failed login attempts or unusual device behavior.

3. Analysis: Correlate events and confirm real incidents.

4. Response: Take immediate action to block or isolate risky devices or users.

5. Reporting: Document incidents for compliance and continuous improvement.

Understanding the SOC cycle helps organizations enforce proactive security and maintain a Zero Trust posture.

4. SIEM and QRadar

SIEM (Security Information and Event Management) collects logs from endpoints, servers, and ZTNA solutions, normalizes data, and identifies threats through correlation and alerts.

IBM QRadar is a SIEM tool used to visualize alerts, analyze suspicious activity, and automate responses. QRadar integrates Zscaler logs to provide insights such as:

- Unauthorized access attempts
- Policy violations
- Device compliance issues

By monitoring ZTNA activity through QRadar, the SOC can detect potential threats before they impact sensitive applications.

5. Threat Intelligence

Threat intelligence feeds (like MISP) provide information about known malicious IP addresses, compromised credentials, and emerging attack patterns. Integrating threat intelligence with ZTNA allows the SOC to update access policies in real-time, ensuring proactive protection.

6. Incident Response

Incident response in a ZTNA environment includes:

- Detecting unauthorized access attempts
- Blocking non-compliant devices immediately
- Reviewing logs and alerts in QRadar
- Documenting actions for future policy improvements

This structured workflow ensures the network remains secure while minimizing operational disruption.

7. College Network Deployment

Our college network includes:

- Servers hosting student and faculty applications
- Wi-Fi access points for staff and students

- Endpoints including laptops, desktops, and lab machines
- Firewall and security appliances

ZTNA implementation ensures:

- Users access only authorized applications
- Internal network remains invisible to unauthorized users
- SOC monitors all activity for security threats

8. Use Case Scenarios

Scenario 1: Secure Remote Access for Faculty to ERP System

Output: Identity verified, device compliant, micro-tunnel to ERP only

Scenario 2: Secure Access for Students to LMS

Output: Identity verified, device compliant, micro-tunnel to LMS only

Scenario 3: Secure Lab Access for IT Staff

Output: Identity verified, device compliant, time-bound micro-tunnel, SOC monitoring

Scenario 4: Block Unauthorized Access

Output: Access denied, alert triggered, network remains protected

Scenario 5: Temporary Access for External Auditors

Output: Identity verified, device compliant, temporary micro-tunnel, automatic revocation

9. Conclusion

Stage 1: Web application testing highlights the importance of identifying vulnerabilities before exploitation.

Stage 2: Nessus vulnerability assessments teach how to detect, prioritize, and remediate risks.

Stage 3: SOC/SEIM with ZTNA shows how real-time monitoring, threat intelligence, and structured incident response maintain a secure environment.

10. Future Scope

Stage 1: AI-driven web application testing for faster detection.
Stage 2: Continuous vulnerability monitoring with automated remediation.
Stage 3: Advanced SOC capabilities using AI and automation for ZTNA enforcement, cloud integration, and predictive threat intelligence.

11. Topics Explored

- SOC and SOC Cycle
- SIEM and QRadar
- Threat Intelligence (MISP)
- Incident Response
- Zero Trust Network Access (ZTNA)
- Zscaler Private Access (ZPA)

12. Tools Explored

- Nessus
- IBM QRadar
- MISP
- Zscaler Private Access